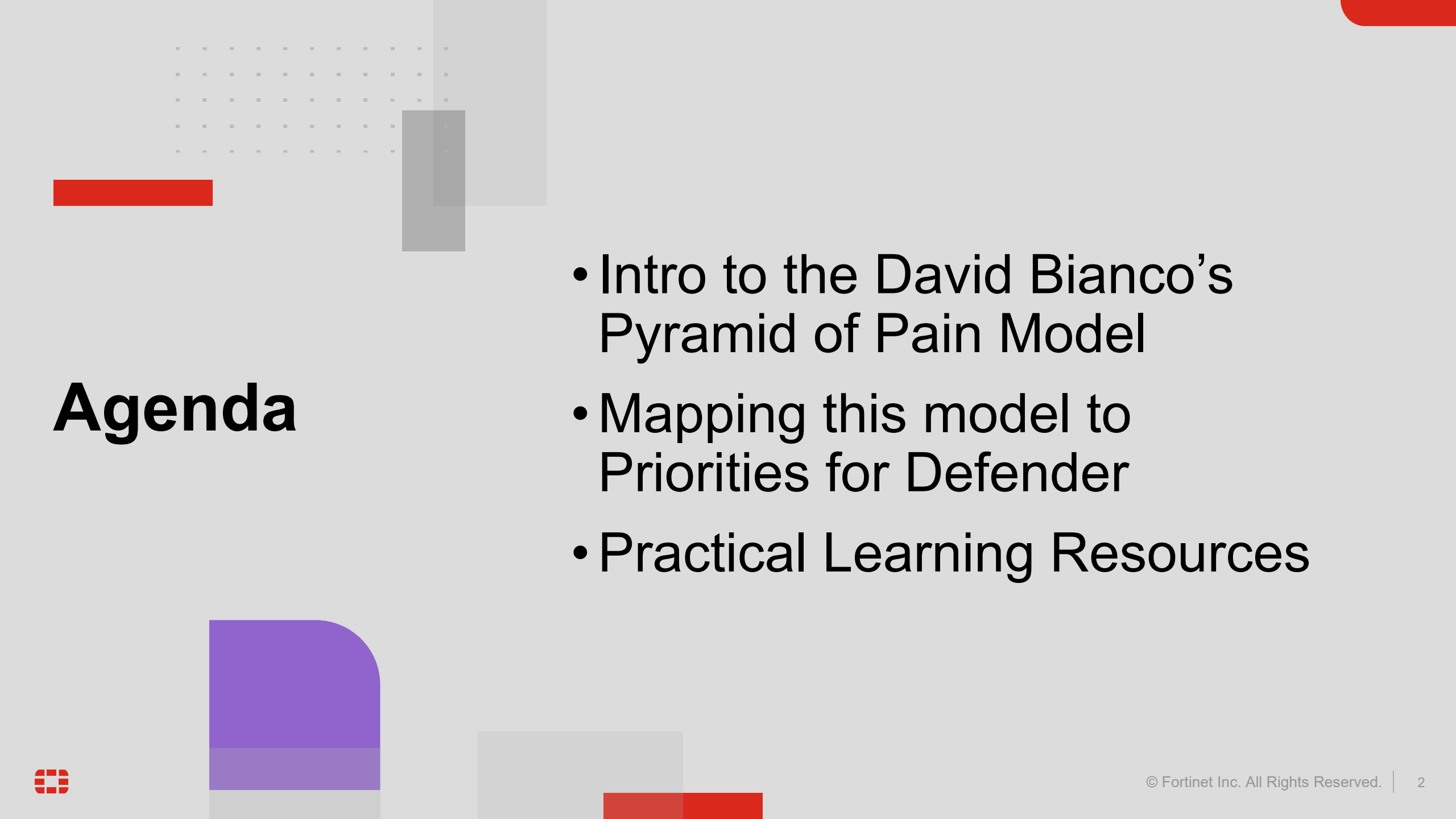


The Fortinet logo, featuring the word "FORTINET" in white capital letters. The letter "O" is replaced by a red square icon with a white grid pattern.

FORTINET

Degrees of Defense: Mapping the Pyramid of Pain to Layered Security Systems

Victor Weis, Consulting Solutions Architect
2025 West Virginia Statewide Technology Conference (WVSTC)



Agenda

- Intro to the David Bianco's Pyramid of Pain Model
- Mapping this model to Priorities for Defender
- Practical Learning Resources



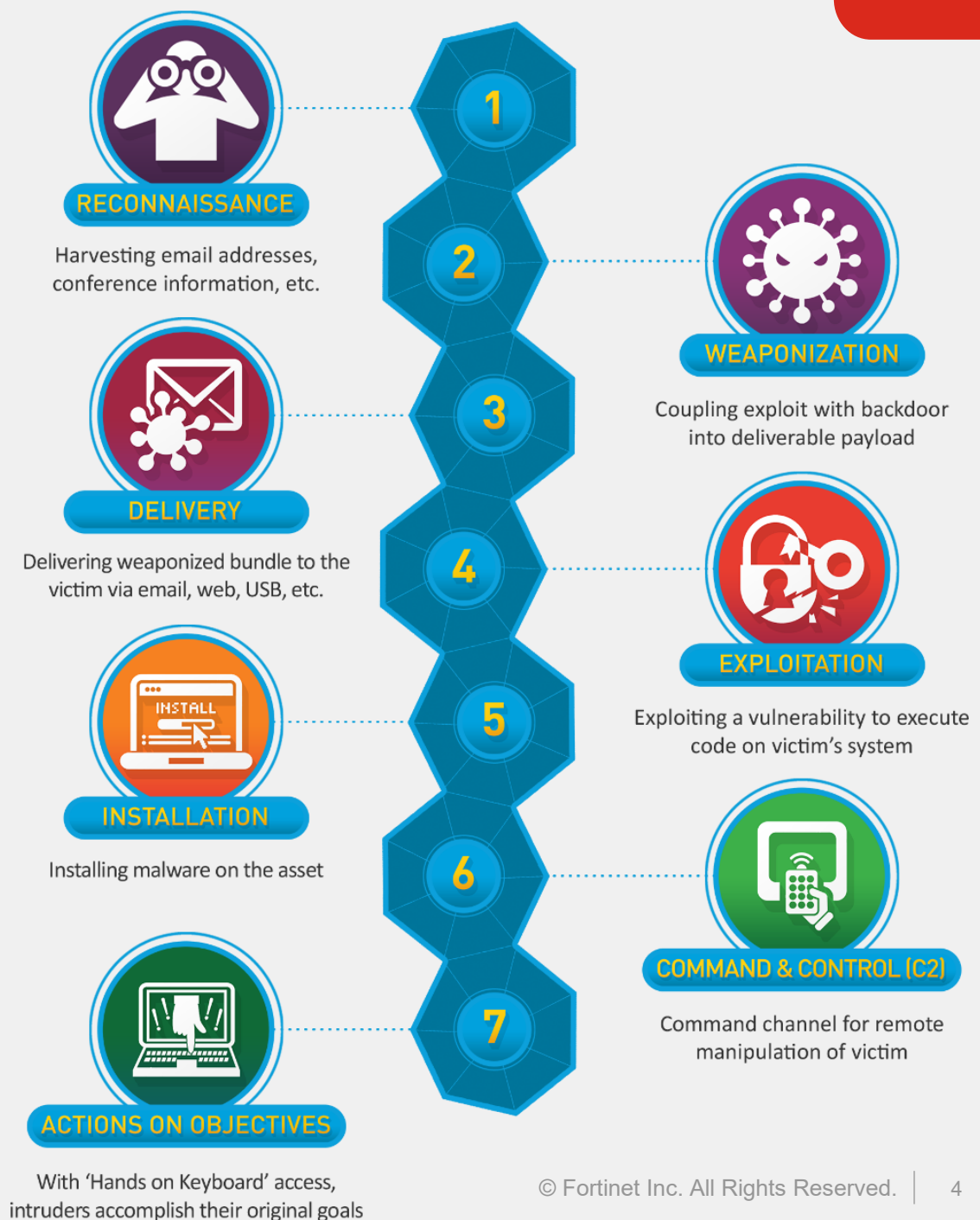
Prioritization of Risk: The Perennial Problem

- The domain of potential threats always exceeds total mitigation capacity
- The threat landscape continuously evolves
- Prioritizing threats by risk is essential for determining mitigation prioritizes
- Prioritizing mitigation tools is important
- But prioritizing mitigation capabilities is more important
- Many tools get purchased, but often the most important capabilities don't get deployed



Defender's Dilemma vs Defender's Advantage

- Ever heard “Defenders must be right all the time, while attackers only need to be right once” ?
- In truth, attackers must be right for many steps in a row – without detection – to be successful.
- Defenders may detect the attack at anyone of these steps
- Attackers have resource constraints too



Locard's Exchange Principle

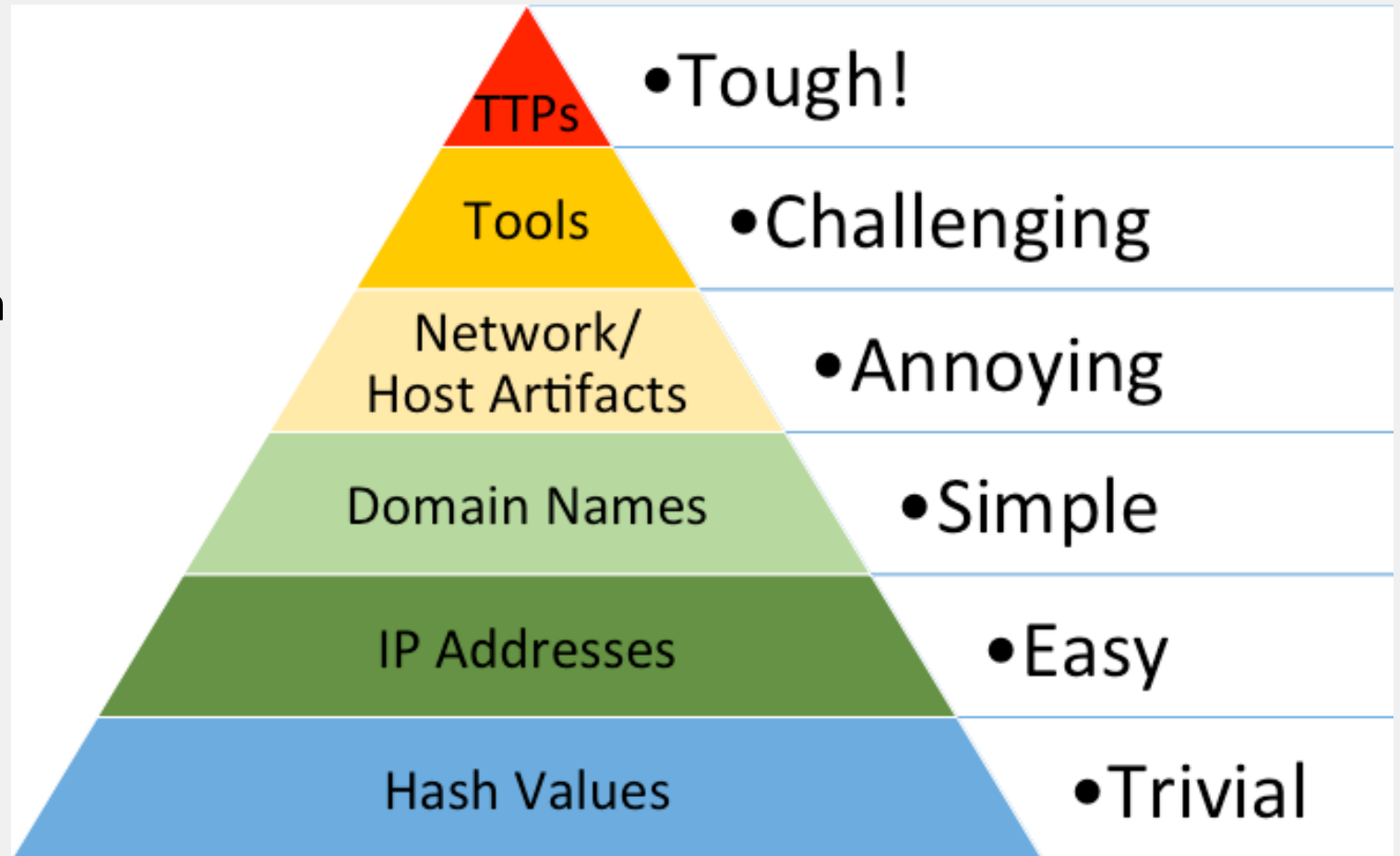
- "Every contact leaves a trace."
~ Dr. Edmond Locard, pioneer of forensic sciences
- In the physical world, traces are naturally left behind
- In the cyber world, we need sensors and data storage (logging) to capture traces (IOCs)
- But which IOCs should we capture for maximum effectiveness?



The Pyramid of Pain: Make Cybercrime Unprofitable

Which Indicators of Compromise (IOCs) provide the best value for security?

- Not all IOCs are created equal.
- Certain IOCs are more difficult to change than others
- The more difficult they are to change, the more pain (cost) you can inflict on the adversary when you can reliably detect them.



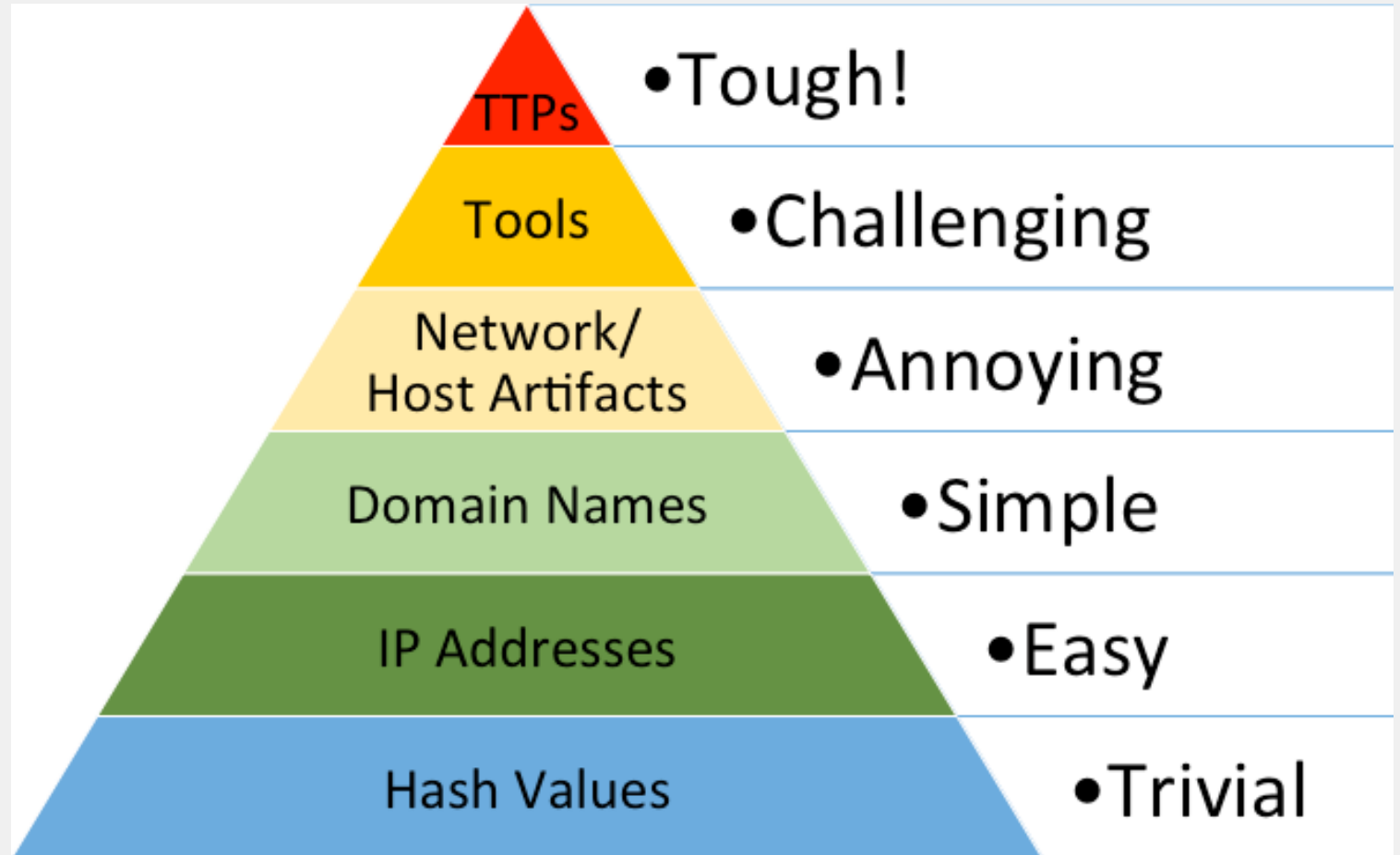
Attribution: David Bianco

Source: <https://www.sans.org/tools/the-pyramid-of-pain/>

The Pyramid of Pain: Make Cybercrime Unprofitable

Which Indicators of Compromise (IOCs) provide the best value for security?

- Detecting Hashes, IPs addresses, Domain Names provides some value
- But it is trivial for attackers to change these
- Detecting Artifacts, Tools, and TTPs provides greater value
- These are much more expensive for the attackers to change



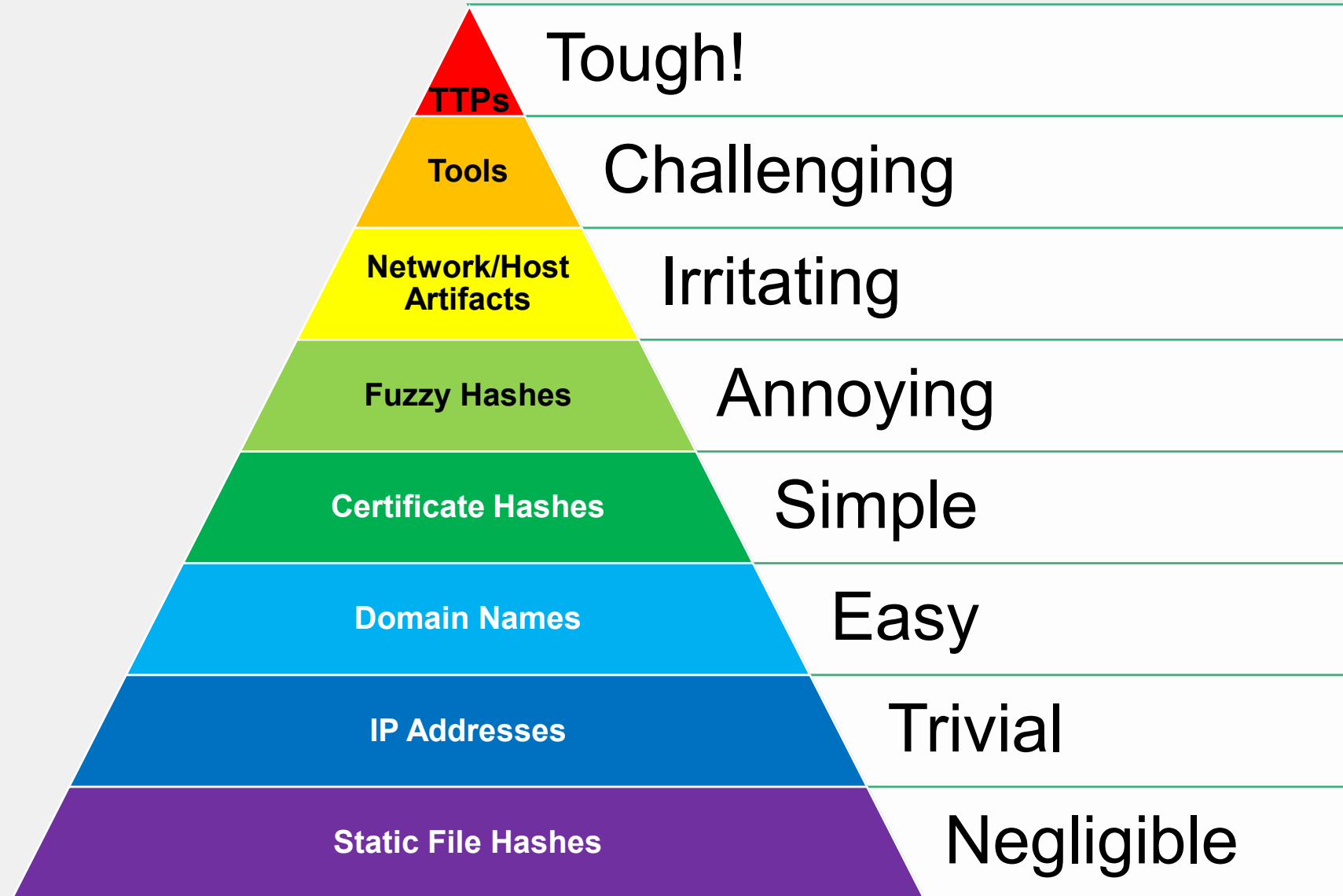
Attribution: David Bianco

Source: <https://www.sans.org/tools/the-pyramid-of-pain/>

Zooming in...

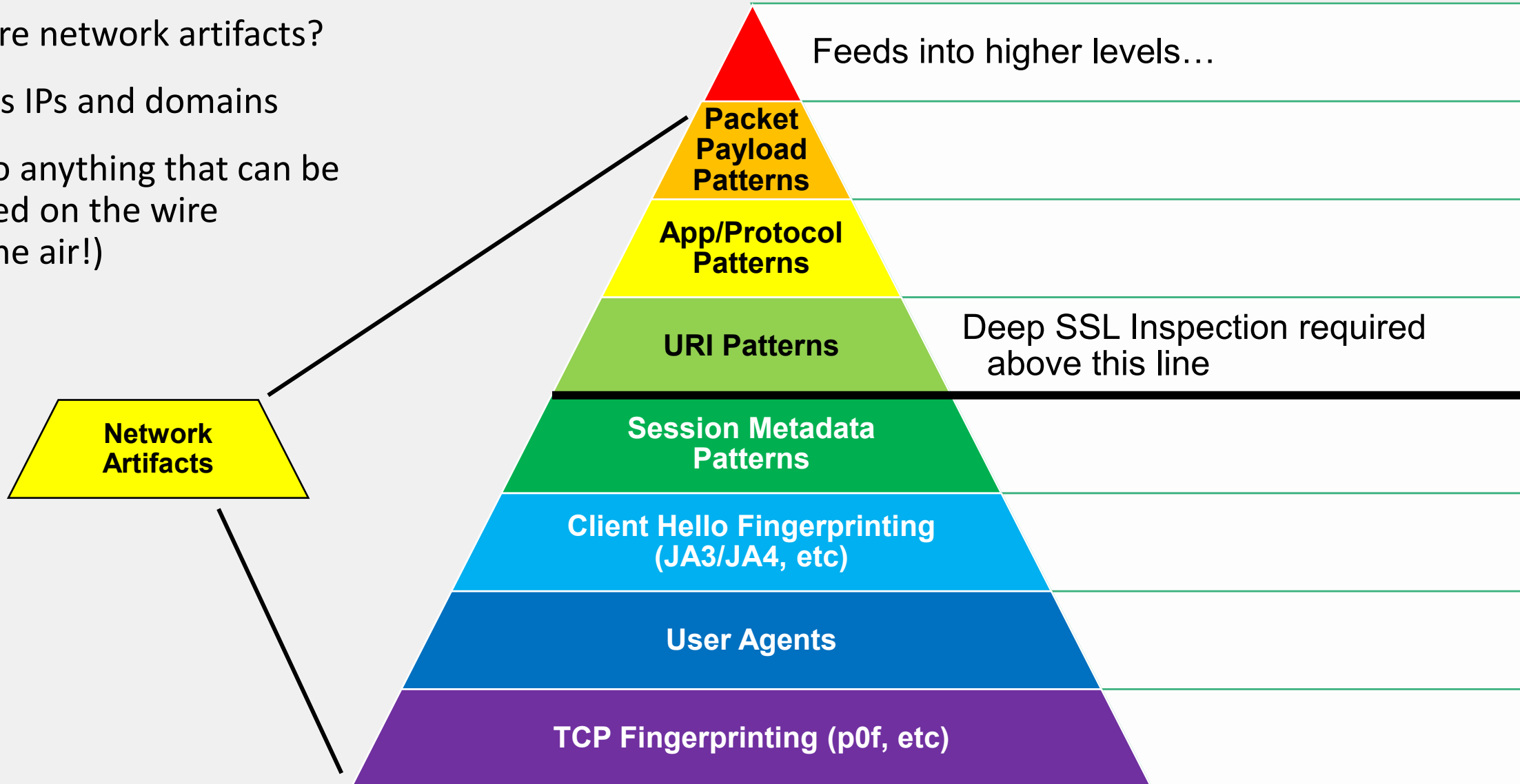
More resolution, more layers

- Static Hashes vs Fuzzy Hashes
 - Ssdeep, sdhash, etc
- Trusted Certificate Hashes vs Domains



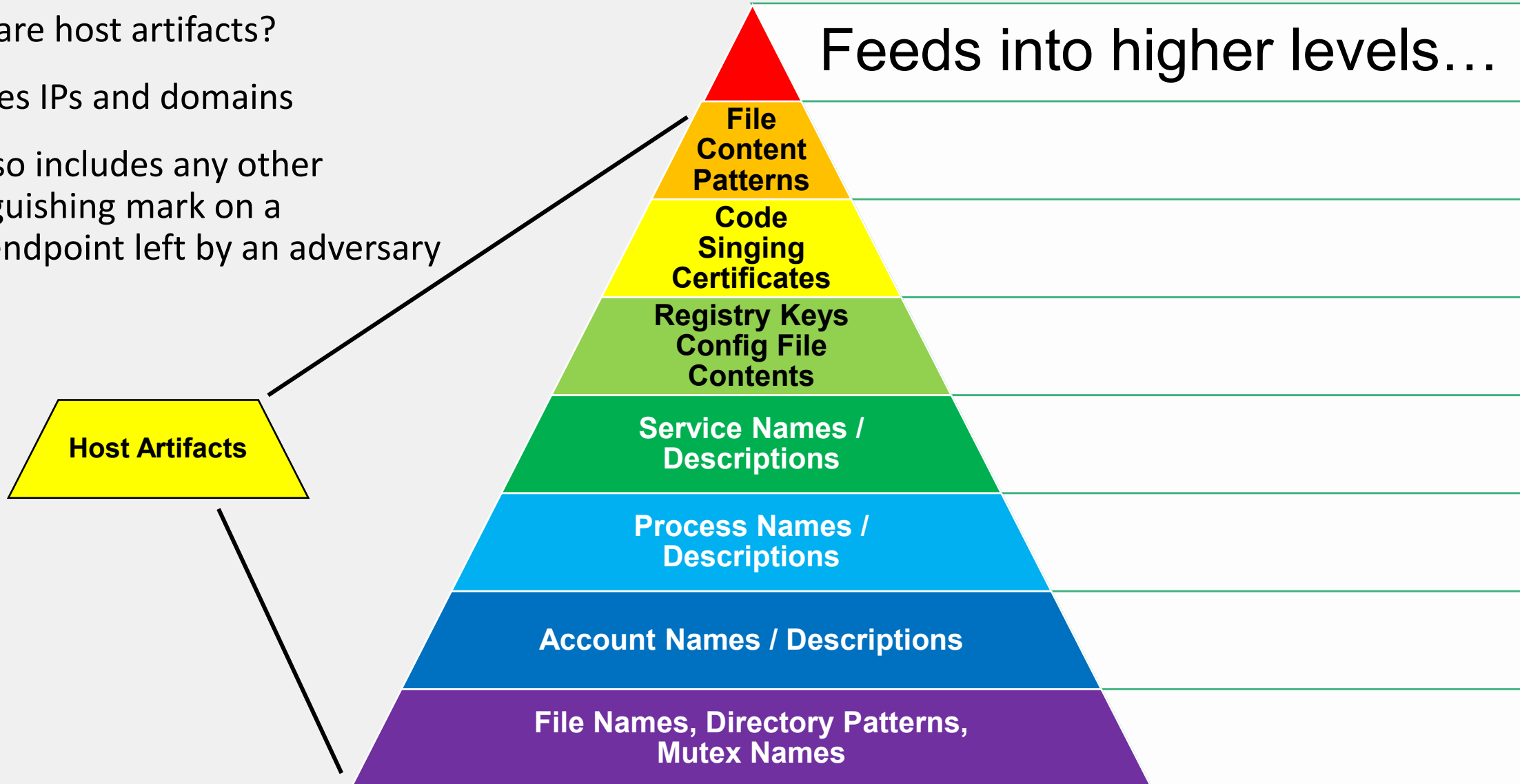
Pyramid of Network Artifacts

- What are network artifacts?
- Includes IPs and domains
- But also anything that can be observed on the wire (or in the air!)



Pyramid of Host Artifacts

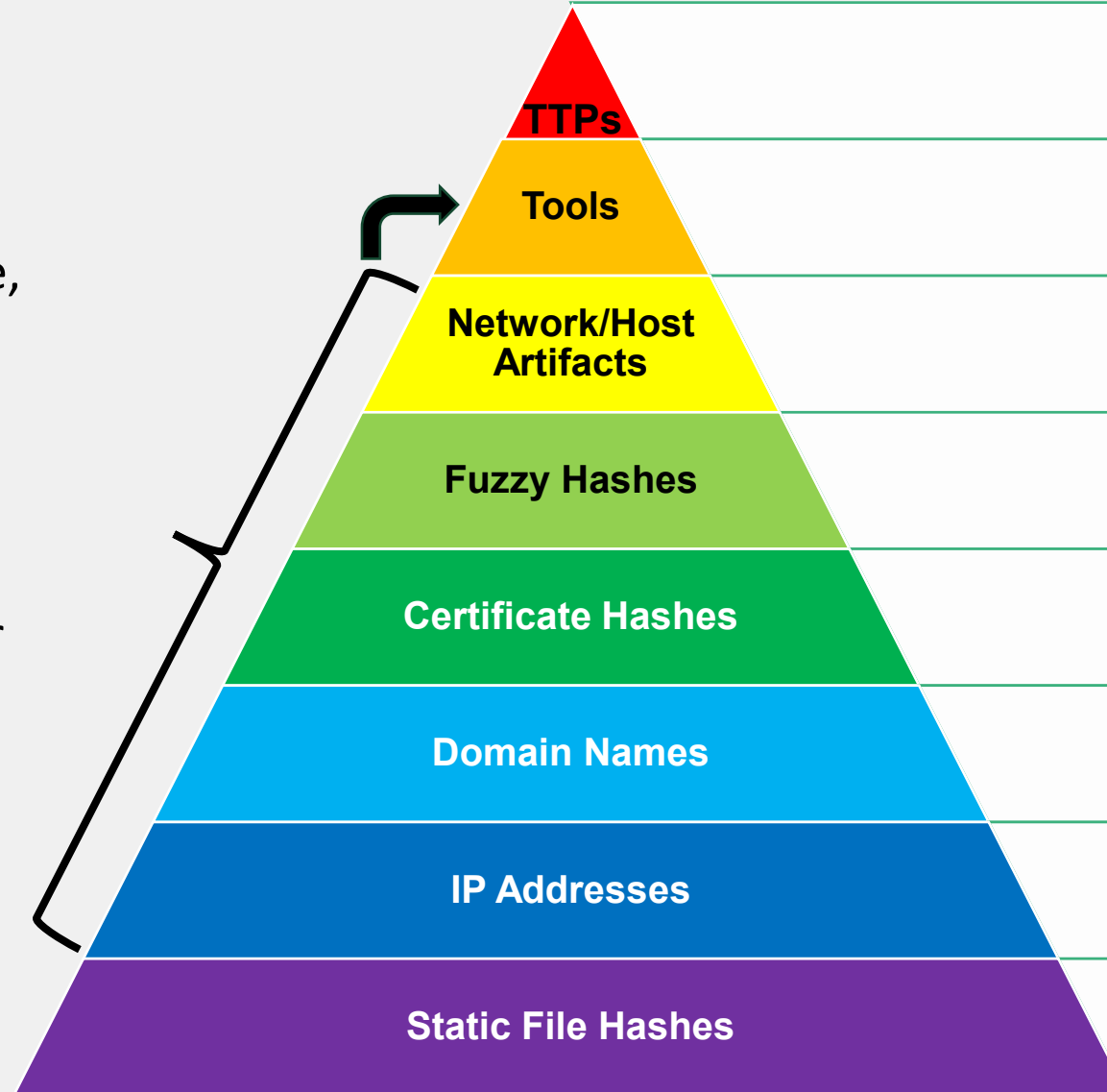
- What are host artifacts?
- Includes IPs and domains
- But also includes any other distinguishing mark on a host/endpoint left by an adversary



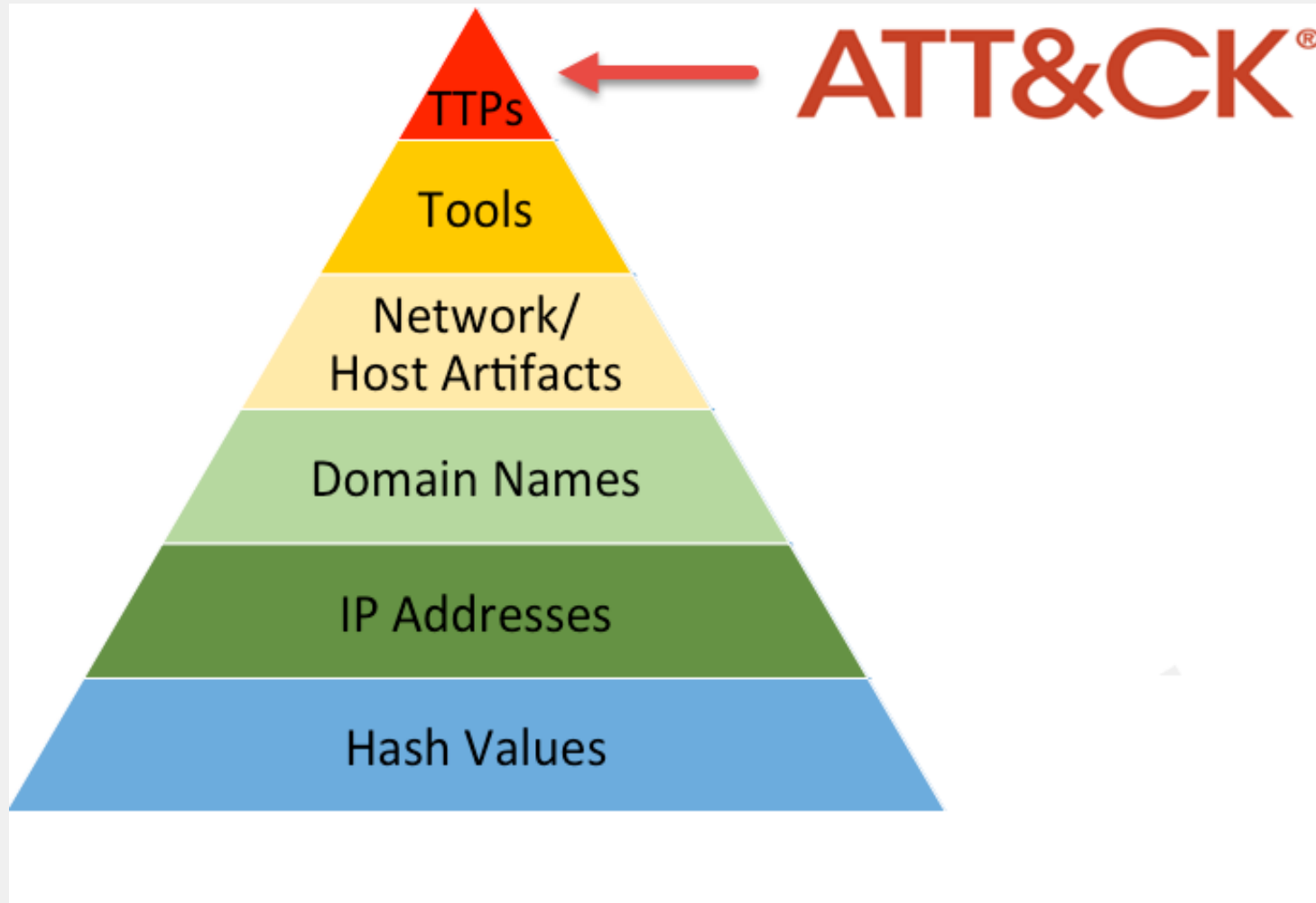
How are Tools defined?

More resolution

- “Tools” refers to any software the adversary uses for their goals
- Mimikatz, Metasploit, Cobalt Strike, X-Agent, etc.
- Can also include improper use of native software (LOTL)
- Effective Tool detection requires correlation of multiple lower-order IOCs



What are Tactics, Techniques, and Procedures?



- Think “Behaviours”
- MITRE ATT&CK Framework – Adversary Tactics Techniques & Common Knowledge
- Knowledge base of TTPs
- A well-known framework for understanding adversary behavior in a cyber-attack.
- Provides a common taxonomy for both offense and defense

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	lateral Movement	Collection	Command and Control	Exfiltration	Impact
10 techniques	7 techniques	9 techniques	13 techniques	19 techniques	13 techniques	42 techniques	17 techniques	30 techniques	9 techniques	17 techniques	16 techniques	9 techniques	13 techniques
Active Scanning (3)	Acquire Infrastructure (7)	Drive-by Compromise	Command and Scripting Interpreter (8)	Account Manipulation (5)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Adversary-in-the-Middle (3)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (3)	Application Layer Protocol (4)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (5)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Gather Victim Identity Information (3)	Compromise Infrastructure (7)	External Remote Services	Deploy Container	Boot or Logon Autostart Execution (14)	Boot or Logon Autostart Execution (14)	Build Image on Host	Credentials from Password Stores (5)	Browser Bookmark Discovery	Lateral Tool Transfer	Audio Capture		Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (6)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Boot or Logon Initialization Scripts (5)	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection	Data Encoding (2)		Data Manipulation (3)
Gather Victim Org Information (4)	Establish Accounts (3)	Phishing (3)	Inter-Process Communication (3)	Browser Extensions	Domain Policy Modification (2)	Deobfuscate/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Services (6)	Browser Session Hijacking	Data Obfuscation (3)	Exfiltration Over C2 Channel	Defacement (2)
Phishing for Information (3)	Obtain Capabilities (6)	Replication Through Removable Media	Native API	Compromise Client Software Binary	Create or Modify System Process (4)	Deploy Container	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (3)	Exfiltration Over Other Network Medium (1)	Endpoint Denial of Service (4)
Search Closed Sources (2)	Stage Capabilities (6)	Supply Chain Compromise (3)	Scheduled Task/Job (5)	Create Account (3)	Domain Policy Modification (2)	Direct Volume Access	Input Capture (4)	Container and Resource Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (2)	Exfiltration Over Physical Medium (1)	Firmware Corruption
Search Open Technical Databases (5)		Trusted Relationship	Serverless Execution	Create or Modify System Process (4)	Escape to Host	Execution Guardrails (1)	Modify Authentication Process (7)	Debugger Evasion	Taint Shared Content	Data from Configuration Repository (2)	Failback Channels	Exfiltration Over Web Service (2)	Inhibit System Recovery
Search Open Websites/Domains (3)		Valid Accounts (4)	Shared Modules	Event Triggered Execution (16)	Event Triggered Execution (16)	Exploitation for Defense Evasion	Multi-Factor Authentication Interception	Domain Trust Discovery	Use Alternate Authentication Material (4)	Data from Information Repositories (3)	Ingress Tool Transfer	Exfiltration Over Web Service (2)	Network Denial of Service (2)
Search Victim-Owned Websites			Software Deployment Tools	Hijack Execution Flow (12)	Hijack Execution Flow (12)	File and Directory Permissions Modification (2)	Multi-Factor Authentication Request Generation	File and Directory Discovery		Data from Local System	Non-Application Layer Protocol	Scheduled Transfer	Resource Hijacking
			User Execution (3)	Implant Internal Image	Process Injection (12)	Hide Artifacts (10)	Network Sniffing	Network Share Discovery		Data from Network Shared Drive	Non-Standard Port	Transfer Data to Cloud Account	Service Stop
			Windows Management Instrumentation	Valid Accounts (4)	Modify Authentication Process (7)	Impair Defenses (9)	OS Credential Dumping (8)	Network Sniffing		Data from Removable Media	Protocol Tunneling		System Shutdown/Reboot
					Office Application Startup (6)	Indicator Removal (9)	Steal Application Access Token	Peripheral Device Discovery		Data Staged (2)	Remote Access Software		
					Pre-OS Boot (5)	Indirect Command Execution	Steal or Forge Kerberos Tickets (4)	Permission Groups Discovery (3)		Email Collection (3)	Traffic Signaling (2)		
					Scheduled Task/Job (5)	Modify Cloud Compute Infrastructure (4)	Steal Web Session Cookie	Query Registry		Input Capture (4)	Web Service (3)		
					Server Software Component (5)	Modify Registry	Unsecured Credentials (7)	Process Discovery		Screen Capture			
					Traffic Signaling (2)	Network Boundary Bridging (1)		Remote System Discovery		Video Capture			
					Valid Accounts (4)	Obfuscated Files or Information (9)		Software Discovery (1)					
						Plist File Modification		System Information Discovery					
						Pre-OS Boot (5)		System Location Discovery (1)					
						Process Injection (12)		System Network Configuration Discovery (1)					
						Reflective Code Loading		System Network Connections Discovery					
						Rogue Domain Controller		System Owner/User Discovery					
						Rootkit		System Service Discovery					
						Subvert Trust Controls (6)		System Time Discovery					
						System Binary Proxy Execution (13)		Virtualization/Sandbox Evasion (3)					
						System Script Proxy Execution (1)		Use Alternate Authentication Material (4)					
						Template Injection		Valid Accounts (4)					
						Traffic Signaling (2)		Virtualization/Sandbox Evasion (3)					
						Trusted Developer Utilities Proxy Execution (1)		Weaken Encryption (2)					
						Unused/Unsupported Cloud Regions		XSL Script Processing					

MITRE ATT&CK - Tactics

TACTICS

Enterprise

Reconnaissance

Resource Development

Initial Access

Execution

Persistence

Privilege Escalation

Defense Evasion

Credential Access

Discovery

Lateral Movement

Collection

Command and Control

Exfiltration

Impact

Mobile

ICS

Enterprise tactics

Tactics represent the "why" of an ATT&CK technique or sub-technique. It is the adversary's tactical goal: the reason for performing an action. For example, an adversary may want to achieve credential access.

Enterprise Tactics: 14

ID	Name	Description
TA0043	Reconnaissance	The adversary is trying to gather information they can use to plan future operations.
TA0042	Resource Development	The adversary is trying to establish resources they can use to support operations.
TA0001	Initial Access	The adversary is trying to get into your network.
TA0002	Execution	The adversary is trying to run malicious code.
TA0003	Persistence	The adversary is trying to maintain their foothold.
TA0004	Privilege Escalation	The adversary is trying to gain higher-level permissions.
TA0005	Defense Evasion	The adversary is trying to avoid being detected.
TA0006	Credential Access	The adversary is trying to steal account names and passwords.
TA0007	Discovery	The adversary is trying to figure out your environment.
TA0008	Lateral Movement	The adversary is trying to move through your environment.
TA0009	Collection	The adversary is trying to gather data of interest to their goal.
TA0011	Command and Control	The adversary is trying to communicate with compromised systems to control them.
TA0010	Exfiltration	The adversary is trying to steal data.
TA0040	Impact	The adversary is trying to manipulate, interrupt, or destroy your systems and data.



MITRE ATT&CK - Tactics

TACTICS

Enterprise

Reconnaissance

Resource Development

Initial Access

Execution

Persistence

Privilege Escalation

Defense Evasion

Credential Access

Discovery

Lateral Movement

[Home](#) > [Tactics](#) > [Enterprise](#) > [Credential Access](#)

Credential Access

The adversary is trying to steal account names and passwords.

Credential Access consists of techniques for stealing credentials like account names and passwords. Techniques used to get credentials include keylogging or credential dumping. Using legitimate credentials can give adversaries access to systems, make them harder to detect, and provide the opportunity to create more accounts to help achieve their goals.

Techniques

ID: TA0006

Created: 17 October 2018

Last Modified: 19 July 2019

[Version Permalink](#)

Techniques: 17



MITRE ATT&CK - Techniques

TACTICS

Enterprise

Reconnaissance

Resource Development

Initial Access

Execution

Persistence

Privilege Escalation

Defense Evasion

Credential Access

Discovery

Lateral Movement

Collection

Command and Control

Exfiltration

Impact

Mobile

ICS

T1003

OS Credential Dumping

Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password, from the operating system and software. Credentials can then be used to perform Lateral Movement and access restricted information.

.001

LSASS Memory

Adversaries may attempt to access credential material stored in the process memory of the Local Security Authority Subsystem Service (LSASS). After a user logs on, the system generates and stores a variety of credential materials in LSASS process memory. These credential materials can be harvested by an administrative user or SYSTEM and used to conduct Lateral Movement using Use Alternate Authentication Material.

.002

Security Account Manager

Adversaries may attempt to extract credential material from the Security Account Manager (SAM) database either through in-memory techniques or through the Windows Registry where the SAM database is stored. The SAM is a database file that contains local accounts for the host, typically those found with the net user command. Enumerating the SAM database requires SYSTEM level access.

.003

NTDS

Adversaries may attempt to access or create a copy of the Active Directory domain database in order to steal credential information, as well as obtain other information about domain members such as devices, users, and access rights. By default, the NTDS file (NTDS.dit) is located in %SystemRoot%\NTDS\Ntds.dit of a domain controller.

.004

LSA Secrets

Adversaries with SYSTEM access to a host may attempt to access Local Security Authority (LSA) secrets, which can contain a variety of different credential materials, such as credentials for service accounts. LSA secrets are stored in the registry at HKEY_LOCAL_MACHINE\SECURITY\Policy\Secrets. LSA secrets can also be dumped from memory.

.005

Cached Domain Credentials

Adversaries may attempt to access cached domain credentials used to allow authentication to occur in the event a domain controller is unavailable.

.006

DCSync

Adversaries may attempt to access credentials and other sensitive information by

ports to capture a larger amount of data.



MITRE ATT&CK – Procedures

Procedure Examples

ID	Name	Description
G0006	APT1	APT1 has been known to use credential dumping using Mimikatz . ^[5]
G0007	APT28	APT28 regularly deploys both publicly available (ex: Mimikatz) and custom password retrieval tools on victims. ^{[6][7]} They have also dumped the LSASS process memory using the MiniDump function. ^[8]
G0022	APT3	APT3 has used a tool to dump credentials by injecting itself into lsass.exe and triggering with the argument "dig." ^[9]
G0050	APT32	APT32 used Mimikatz and customized versions of Windows Credential Dumper to harvest credentials. ^{[10][11]}
G0064	APT33	APT33 has used a variety of publicly available tools like LaZagne, Mimikatz , and ProcDump to dump credentials. ^{[12][13]}
G0087	APT39	APT39 has used Mimikatz, Windows Credential Editor and ProcDump to dump credentials. ^[14]
G0096	APT41	APT41 has used hashdump, Mimikatz , and the Windows Credential Editor to dump password hashes from memory and authenticate to other user accounts. ^{[15][16]}
G0143	Aquatic Panda	Aquatic Panda has attempted to harvest credentials through LSASS memory dumping. ^[17]
S0606	Bad Rabbit	Bad Rabbit has used Mimikatz to harvest credentials from the victim's machine. ^[18]



MITRE ATT&CK – Mitigations

Mitigations

ID	Mitigation	Description
M1040	Behavior Prevention on Endpoint	On Windows 10, enable Attack Surface Reduction (ASR) rules to secure LSASS and prevent credential stealing. ^[82]
M1043	Credential Access Protection	With Windows 10, Microsoft implemented new protections called Credential Guard to protect the LSA secrets that can be used to obtain credentials through forms of credential dumping. It is not configured by default and has hardware and firmware system requirements. It also does not protect against all forms of credential dumping. ^{[83][84]}
M1028	Operating System Configuration	Consider disabling or restricting NTLM. ^[85] Consider disabling WDigest authentication. ^[86]
M1027	Password Policies	Ensure that local administrator accounts have complex, unique passwords across all systems on the network.
M1026	Privileged Account Management	Do not put user or admin domain accounts in the local administrator groups across systems unless they are tightly controlled, as this is often equivalent to having a local administrator account with the same password on all systems. Follow best practices for design and administration of an enterprise network to limit privileged account use across administrative tiers.
M1025	Privileged Process Integrity	On Windows 8.1 and Windows Server 2012 R2, enable Protected Process Light for LSA. ^[87]
M1017	User Training	Limit credential overlap across accounts and systems by training users and administrators not to use the same password for multiple accounts.



MITRE ATT&CK – Detection

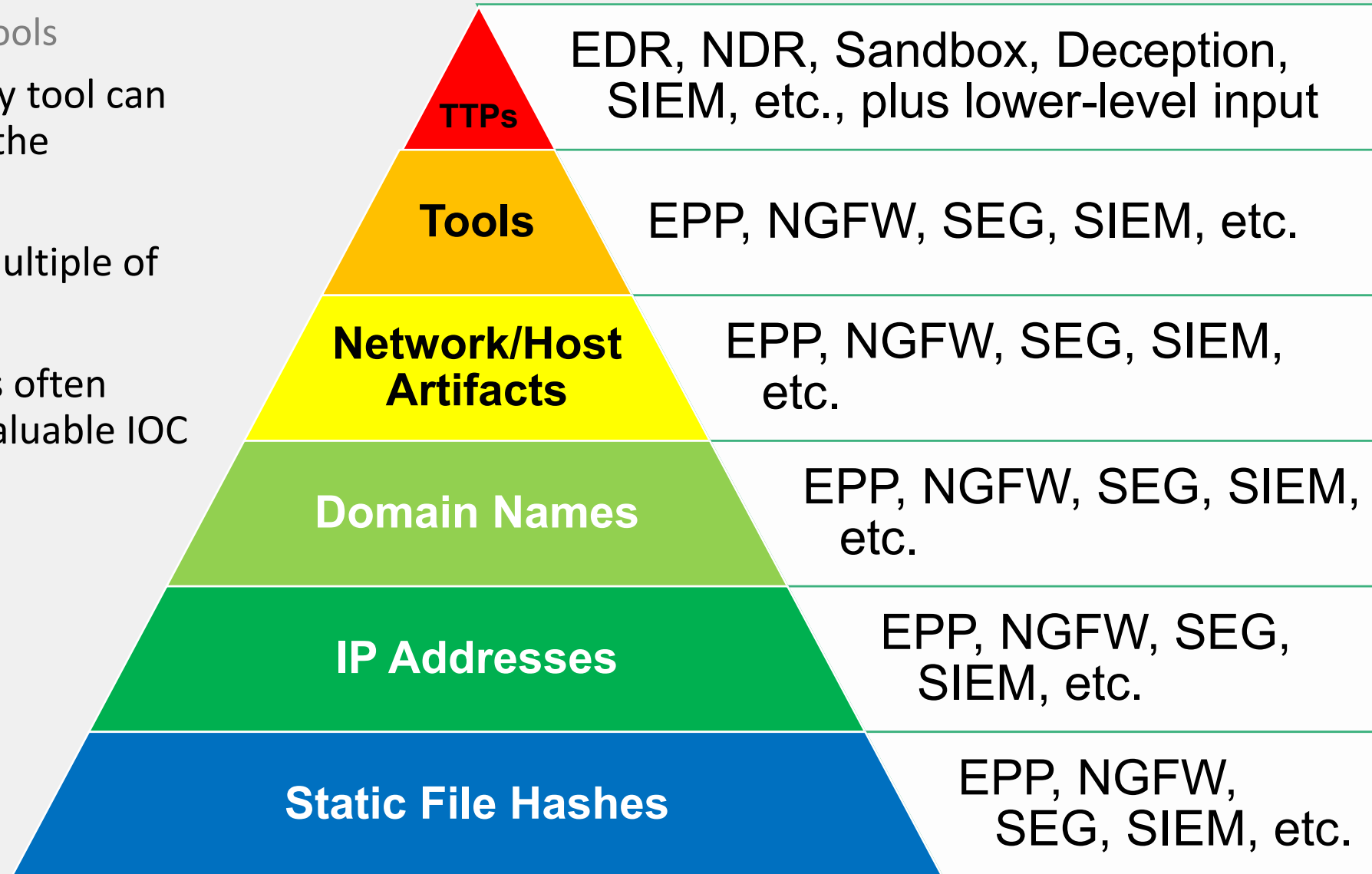
Detection			
ID	Data Source	Data Component	Detects
DS0017	Command	Command Execution	Monitor executed commands and arguments that may attempt to access credential material stored in the process memory of the Local Security Authority Subsystem Service (LSASS). Remote access tools may contain built-in features or incorporate existing tools like Mimikatz. PowerShell scripts also exist that contain credential dumping functionality, such as PowerSploit's Invoke-Mimikatz module, ^[88] which may require additional logging features to be configured in the operating system to collect necessary information for analysis.
DS0009	Process	OS API Execution	Monitor for API calls that may attempt to access credential material stored in the process memory of the Local Security Authority Subsystem Service (LSASS).
		Process Access	Monitor for unexpected processes interacting with LSASS.exe. ^[89] Common credential dumpers such as Mimikatz access LSASS.exe by opening the process, locating the LSA secrets key, and decrypting the sections in memory where credential details are stored. Credential dumpers may also use methods for reflective Process Injection to reduce potential indicators of malicious activity.
		Process Creation	Monitor for newly executed processes that may be indicative of credential dumping. On Windows 8.1 and Windows Server 2012 R2, monitor Windows Logs for LSASS.exe creation to verify that LSASS started as a protected process.



IOC Mapping for Defenders

Focus on capabilities within tools

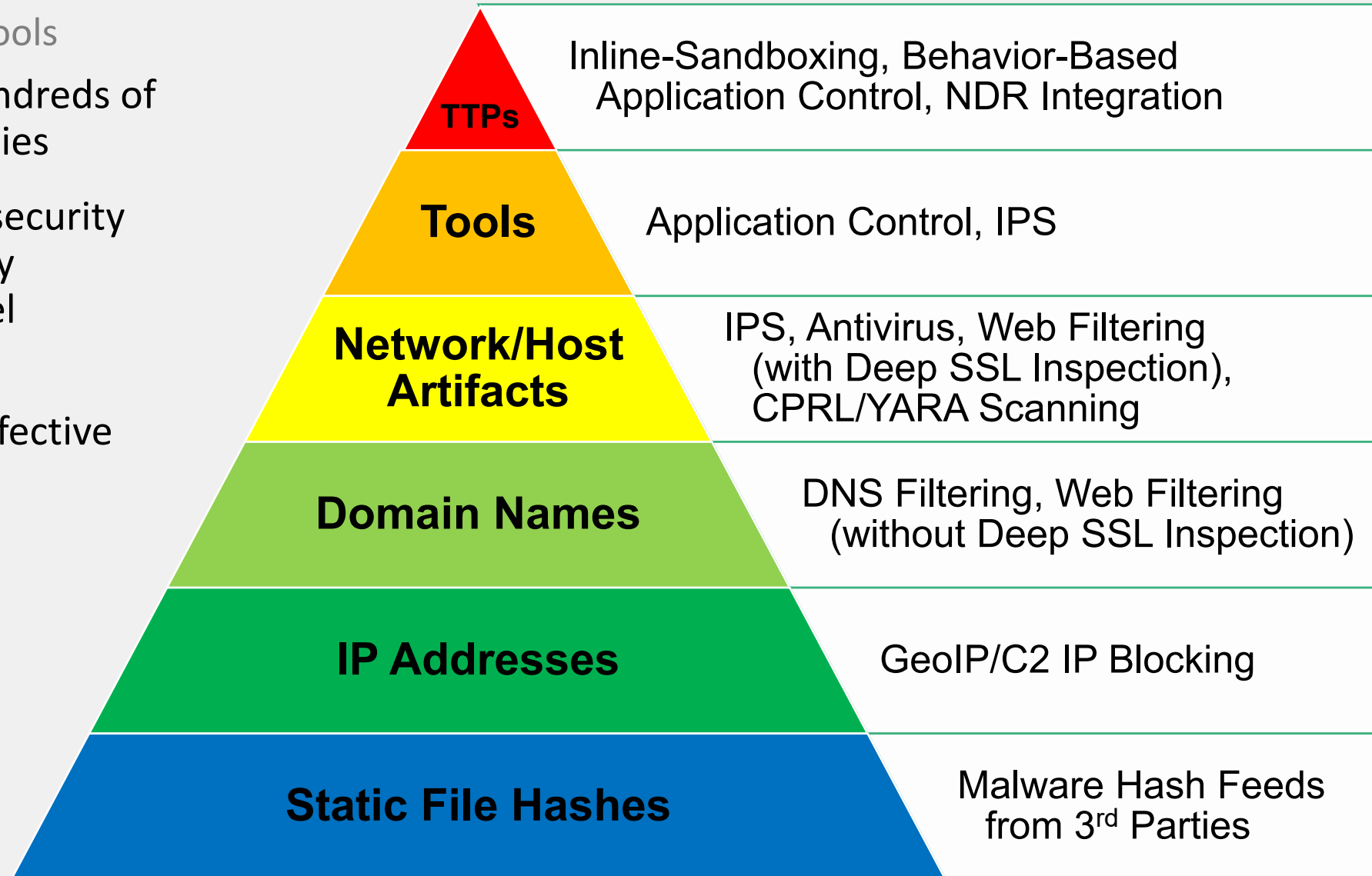
- Almost every cybersecurity tool can play some role at each of the different IOCs levels
- Many orgs already have multiple of these tools
- But their implementations often don't focus on the most valuable IOC levels



Example: FortiGate NGFW AV Engine

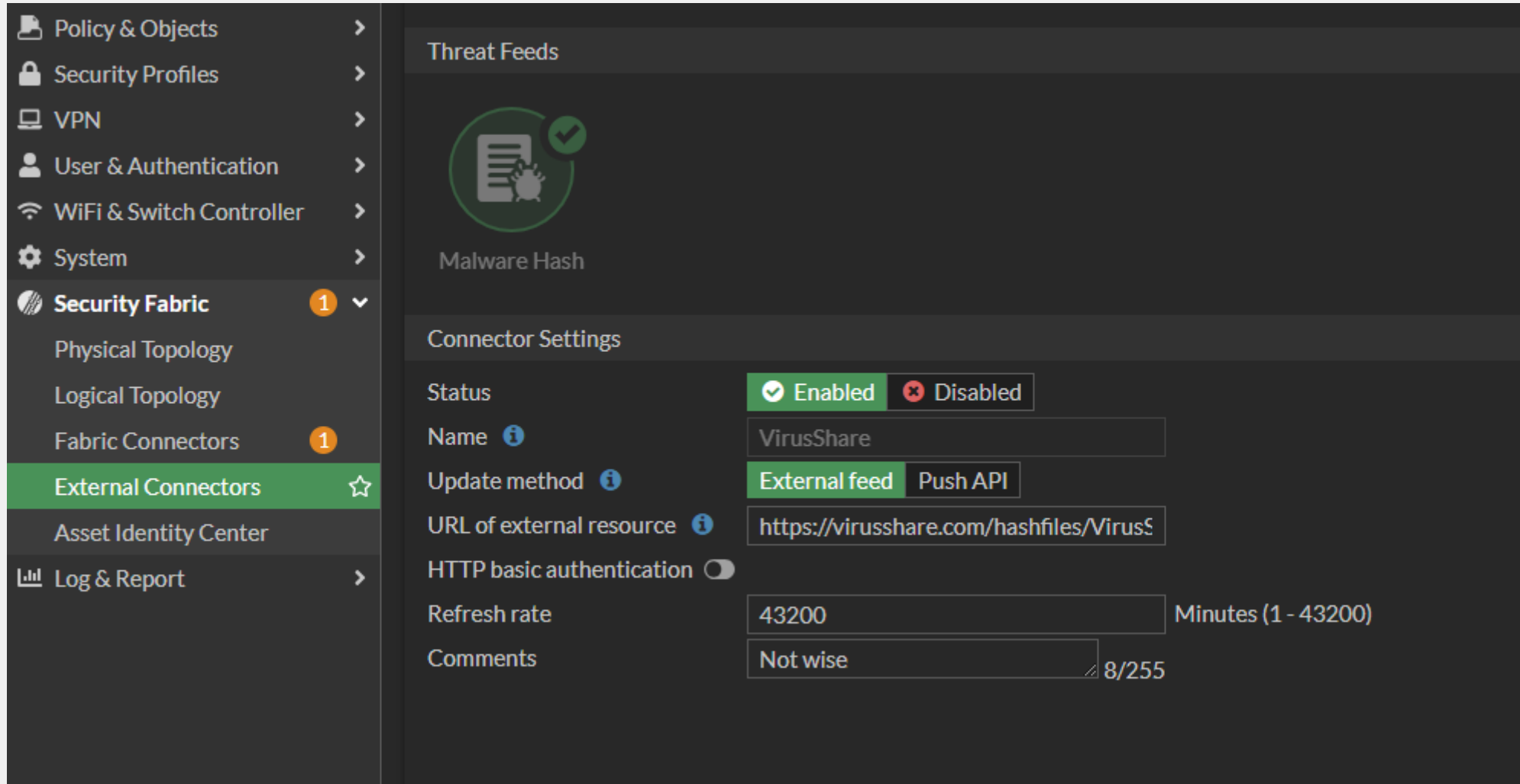
Focus on capabilities within tools

- A FortiGate NGFW has hundreds of different security capabilities
- But the actual impact for security effectiveness varies greatly depending on the IOC level
- Focus your resources on implementing the most effective capabilities



Capability Mapping on FortiOS

External Malware Hash Feed for FortiOS – Not very useful!



The screenshot displays the FortiOS configuration interface for External Connectors. The left sidebar contains the following menu items: Policy & Objects, Security Profiles, VPN, User & Authentication, WiFi & Switch Controller, System, Security Fabric (with a notification badge), Physical Topology, Logical Topology, Fabric Connectors (with a notification badge), External Connectors (highlighted with a star), Asset Identity Center, and Log & Report. The main content area is titled 'Threat Feeds' and features a 'Malware Hash' icon. Below this, the 'Connector Settings' section is visible, containing the following fields:

- Status: ☒ Enabled ☐ Disabled
- Name:
- Update method: ☒ External feed ☐ Push API
- URL of external resource:
- HTTP basic authentication: ☐
- Refresh rate: Minutes (1 - 43200)
- Comments: 8/255

Capability Mapping on FortiOS

External Malware Hash Feed for FortiOS – Not very useful!

Malware Hash Threat Feed VirusShare	
Search	
Entry	
2d75cc1bf8e57872781f9cd04a529256	
00f538c3d410822e241486ca061a57ee	
3f066dd1f1da052248aed5abc4a0c6a1	
781770fda3bd3236d0ab8274577dddde	
86b6c59aa48a69e16d3313d982791398	
42914d6d213a20a2684064be5c80ffa9	
10699ac57f1cf851ae144ebce42fa587	
248338632580f9c018c4d8f8d9c6c408	
999eb1840c209aa70a84c5cf64909e5f	
12c4201fe1db96a1a1711790b52a3cf9	
427988b7f16152b0961e20d710f0509d	
4209aba2d2d252b98d98df499206b6d1	

Entry Count

131,072 Valid

View Entries

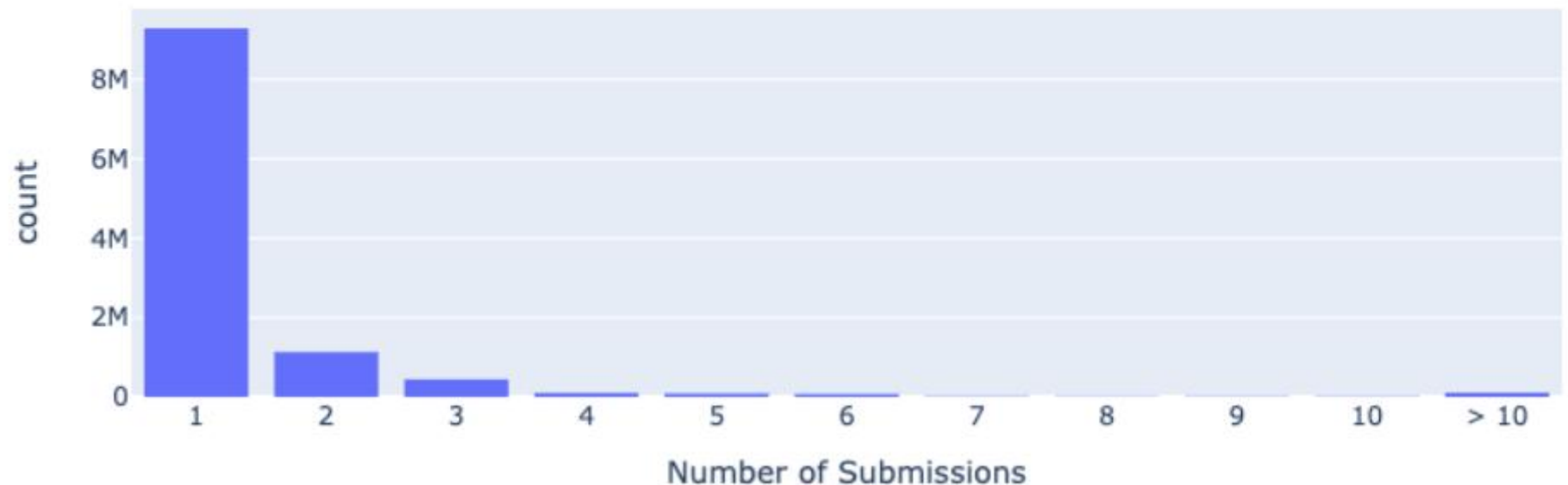


Capability Mapping on FortiOS

External Malware Hash Feed for FortiOS – Not very useful!

- There's maybe an 8% chance (at best) for ever detecting these 3rd-party hashes on your networks
- David Bianco ran the numbers using the VirusTotal database: <https://detect-respond.blogspot.com/2022/04/stop-using-hashes-for-detection-and.html>

Malware Hash Submission Counts



Capability Mapping on FortiOS

Inline Sandboxing – Much more useful!

Sandbox Settings

Status

✓ Enabled

✗ Disabled

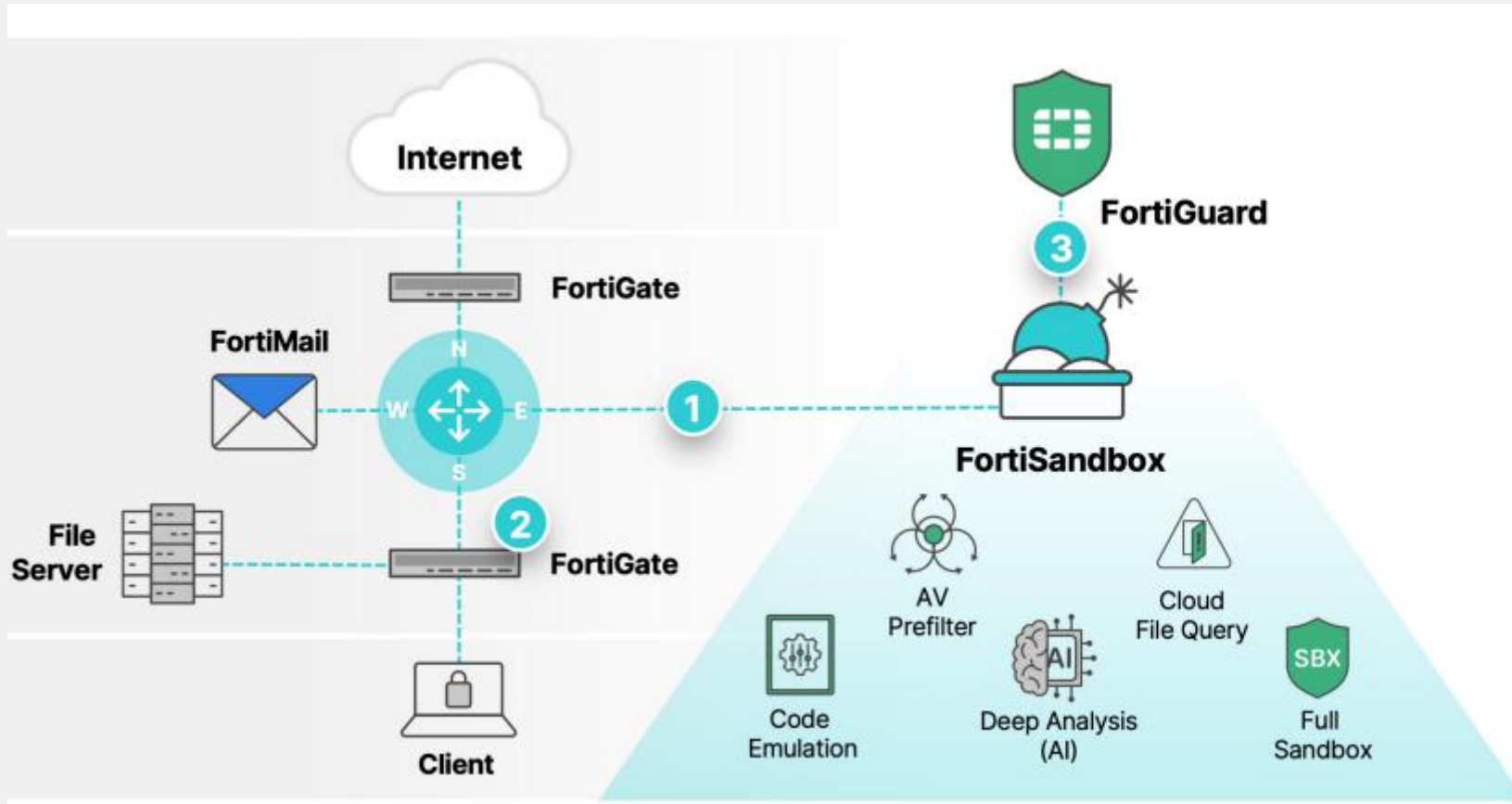
Type

FortiSandbox

FortiGate Cloud

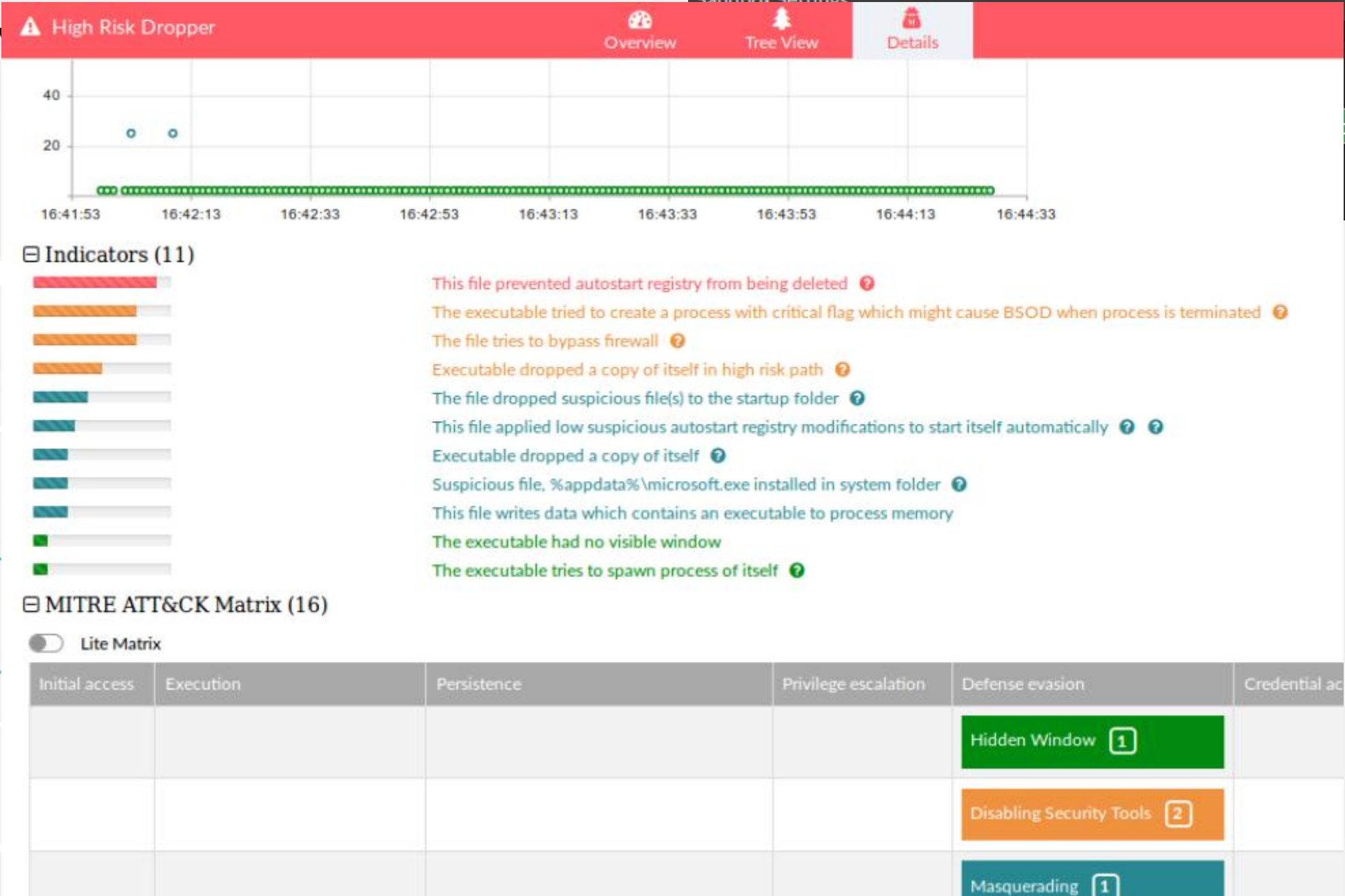
FortiSandbox Cloud

Inline scan



Capabilities

Inline Sandbo



Capability Mapping on FortiOS

Blocking Applications with Evasive/Tunneling/C2 Behavior

Application and Filter Overrides

Create New

Edit

Delete

Priority	Details	Type	Action
1	BHVR Evasive	Filter	Block
	BHVR Tunneling		
	BHVR Botnet		
1			

Name	Category
DNS.TXT.Records.Tunneling	Proxy
DNSTunnel	
DroidVPN	
Finch.VPN	
Freagate.Searching	
HoSProxy	
Hola.Unblocker	



DNS.TXT.Records.Tunneling

ID39624

SummaryThis indicates an attempt to tunnel traffics via DNS TXT Records.

CategoryProxy

Risk

Popularity☆☆☆☆☆

ProtocolUDP, DNS, TCP

PortsTCP/53, UDP/53

TechnologyClient-Server

BehaviorEvasive, Tunneling

VendorOther

Mitre ATT&CK Resources

All Free!

- <https://attack.mitre.org> - the database itself
- <https://mitre-attack.github.io/attack-navigator/> - the tool that lets you build ATT&CK maps
- <https://center-for-threat-informed-defense.github.io/attack-flow/ui/> - the attack flow tool that lets you map the progression of TTPs in detail
- <https://github.com/mitre/caldera> - MITRE's automated threat simulator
- <https://app.cybrary.it/my-learning> - free MITRE training
- <https://mad20.io/> - MITRE certification path



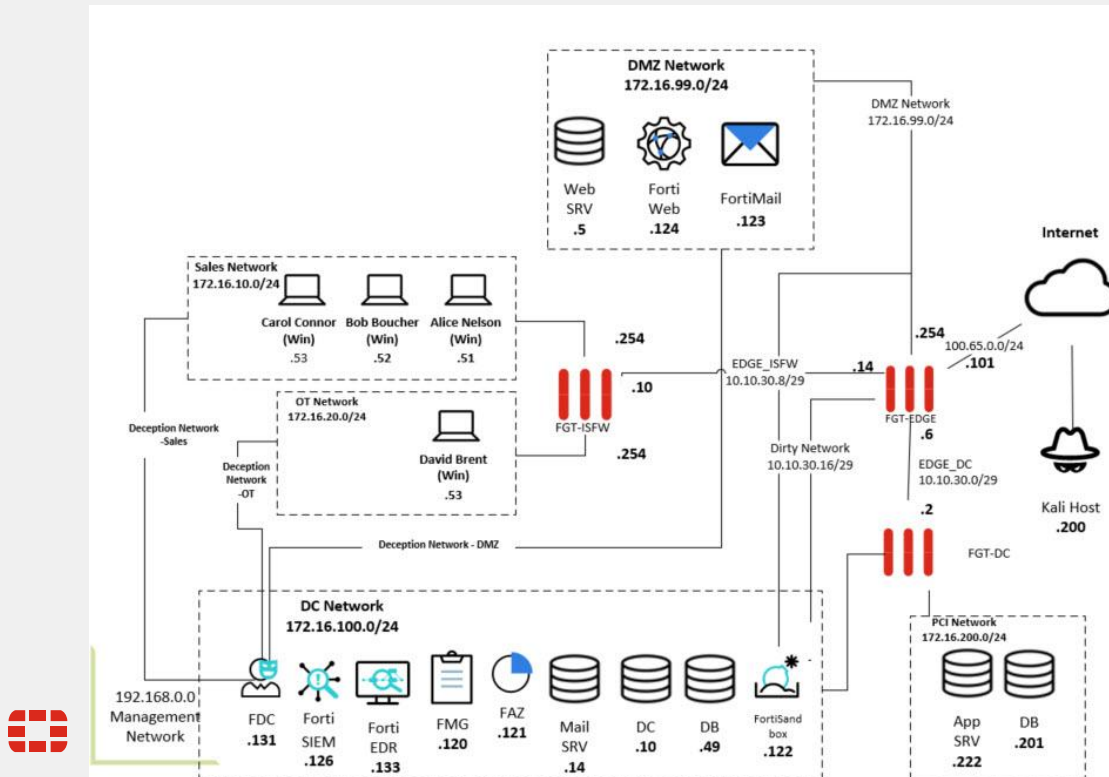
Fortinet Fast Track Workshops

FREE Hands-on virtual labs! Gain CPE creds for ISC2 renewals

- Fast Track Fridays Registration:
<https://events.fortinet.com/fortinetfasttrackworkshops/end-users>
- Custom times available for organization events upon request.

Workshop:

Threat Hunting using Mitre ATT&CK™ TTPs to Identify Adversarial Behaviors



EVENTS						
Archive Mark As... Export Handle Event Delete Forensics Exception Manager						
☐ All	ID	DEVICE	PROCESS	CLASSIFICATION	DESTINATIONS	RECEIVED
WKS-JUMBOX-Z10 (5 events)						
SRV-WS-IIS-A1 (11 events)						
☐	10519	SRV-WS-IIS-A1	backdoor.exe	Malicious	2 destinations	24-Mar-2023, 12:10:00
Logged-In User: Process owner: Certificate: Process path: Raw Data Items:						
None Local System Unsigned C:\inetpub\wwwroot\uploads\backdoor.exe 2						
☐	10490	SRV-WS-IIS-A1	backdoor.exe	Malicious	100.64.1.200	24-Mar-2023, 11:56:19
☐	10462	SRV-WS-IIS-A1	WMIC.exe	Malicious	Sensitive Infor...	24-Mar-2023, 11:56:19
☐	10409	SRV-WS-IIS-A1	backdoor.exe	Malicious	File Creation	24-Mar-2023, 11:33:33
☐	10372	SRV-WS-IIS-A1	backdoor.exe	Malicious	File Delete Atte...	24-Mar-2023, 11:23:29
☐	10386	SRV-WS-IIS-A1	backdoor.exe	Malicious	Service Access	24-Mar-2023, 11:23:29
☐	10340	SRV-WS-IIS-A1	backdoor.exe	Malicious	Service Access	24-Mar-2023, 11:20:16
☒	10354	SRV-WS-IIS-A1	backdoor.exe	Malicious	Network Access	24-Mar-2023, 11:20:16
☐	10326	SRV-WS-IIS-A1	backdoor.exe	Malicious	100.64.1.200	24-Mar-2023, 11:20:15
☐	10303	SRV-WS-IIS-A1	backdoor.exe	Malicious	File Read Atte...	24-Mar-2023, 11:20:15

Fortinet Fast Track Workshops

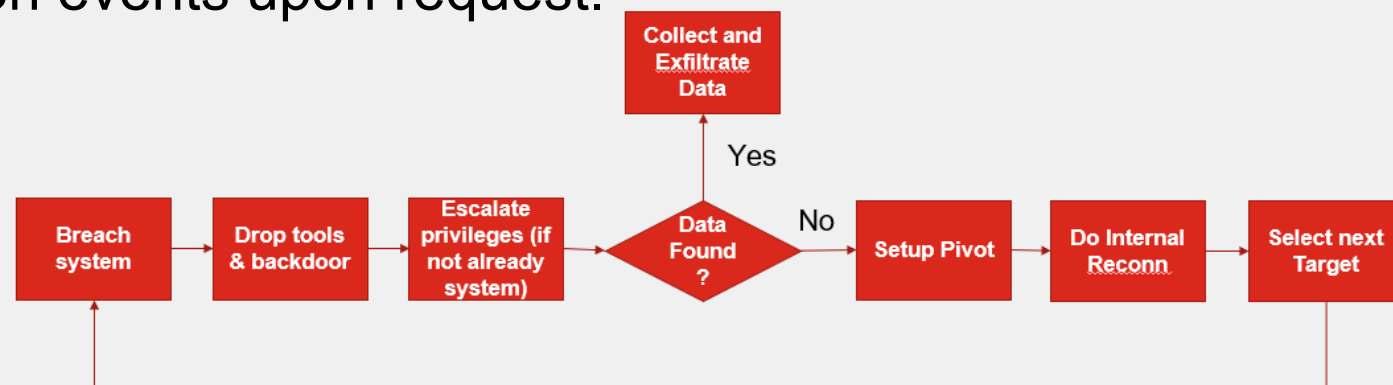
FREE Hands-on virtual labs! Gain CPE creds for ISC2 renewals

- Fast Track Fridays Registration:
<https://events.fortinet.com/fortinetfasttrackworkshops/end-users>
- Custom times available for organization events upon request.

Workshop: Attack and Defend Challenge

Exercise: Scenario

- You have targeted AcmeCorp as your victim, you are after their client's credit card details
- You have already breached their network once using a sphear phishing attack, however the attack was discovered and your access to their network was terminated
- Before you were discovered you internal reconnaissance determined that the credit card information was on database server on the AcmeCorp 'PCI' network
- Your subsequent phishing attacks to breach the network a second time have failed (spoiler alert: you will see why in the Defend Challenge)
- During your initial reconnaissance you uncovered a supplier portal, <https://suppliers.acmecorp.net> which appears to be subject to an application layer attack
- Your next steps are to compromise this web server in order to gain access to their network



Attack Challenge

- In this exercise you will take the role of the Threat Actor
- You will be asked to complete 20 Objectives
- The Objectives will lead you through the attack
- There are points given for each objective, the team with the most points is the winner
 - 400 points for the Attack Phase
 - Also 400 points for the Defend Phase
 - You can track your progress using the Leaderboard
- If you are stuck, there are hints (at a cost)



Defend Challenge – Breaking the Kill Chain

- In this exercise you will take the role of securing AcmeCorp
- AcmeCorp has made an investment in security to order break the Kill Chain
- You will be asked to complete 12 Objectives to stop the attack which was carried out in Attack Challenge
- You will be using FortiWeb, FortiGate, FortiSandbox, FortiClient-EMS, FortiMail and FortiManager/FortiAnalyzer.
- You will be asked to configure the solution and then test the configuration and will be automatically scored based on success outlined criteria
- If you are stuck, you have access to the there are hints (at a cost)
- **NOTE: Second User can now log into the Jumpbox using USER2 (password *****)**



Questions, Comments, Feedback

How to contact me

- Email: vweis@fortinet.com
- GitHub: <https://github.com/weis-victor>
- LinkedIn: <https://www.linkedin.com/in/victor-weis/>



FORTINET®